Galaxy Control Systems Firmware Threat Brief

Galaxy Control Systems Firmware Attack Surface & Detection Brief

Scope: Windows-side management software only, acquired 2026-10-23. **No panel firmware has been obtained or extracted.** Everything below rests either on VirusTotal metadata for three real `SystemGalaxy.exe` builds, or on vendor/product documentation — and where a claim could not be supported, that is stated rather than filled in.

Why this brief exists now: Galaxy was the largest OT vendor in the ARNG census with **no threat brief at all** — 463 OT devices across 19 states — while 968 hashes had already been collected. The material existed; only the write-up was missing. See vendor-exposure-vs-coverage.md.

Identity — the census name is not the vendor name

The census reports this vendor as **"Digital Systems Corp"** (OUI owner). The operating company is **Galaxy Control Systems**, and the product line is **System Galaxy**. Anyone searching the census string will find nothing useful; anyone searching the product name hits a severe name collision (Samsung Galaxy, GOG Galaxy, the Galaxy bioinformatics platform), which is a practical obstacle worth knowing before researching this vendor.

Platform, per `firmware-staging/Digital-Systems-Corp/README.md`: System Galaxy software over **508 / 508i / 600 / 635** series controller panels, **DIGIPROX** readers, and GCS IP intercoms.

Property	Value
Census vendor string	`Digital Systems Corp`
OT devices	**463** (492 across all categories)
States	19
Purdue placement	Panels at L1/L2 (door strike / reader I/O); System Galaxy server at **L3**
Threat brief before today	**none**

Acquisition — the vendor portal is still closed

`partner.galaxysys.com/software` requires partner credentials. The owner registered and is **pending approval** (2026-10-22), so no vendor-channel download has happened.

What we hold came from **VirusTotal Intelligence sample download** instead. That route yields vendor **software**, never device firmware — nobody submits access-control panel images to VT — so the 508/600/635 panel firmware remains entirely unobtained.

What was acquired, and what the metadata says

Three genuine `SystemGalaxy.exe` builds, all `CompanyName = Galaxy Control Systems`:

SHA256 (first 16)	Bytes	Declared version	First seen in VT	Detections	PE resources
`35E138A4481710B7`	10,893,824	**11.7.0.1**	2021-04-07	0 / 69	132
`A0EAFE8486C71E10`	10,920,960	**11.8.3.1**	2023-03-27	0 / 73	101
`67B90FDF5900F857`	10,997,520	**11.8.3.1**	2025-11-07	0 / 72	101

Extraction yields **3,055 files**, but these are the PE **resource section** (824 `.ico`, 627 `.bmp`, menus, typelibs) — not a filesystem. There is no rootfs here to baseline, and the hash count overstates the analytical depth. Said plainly so the 968 figure is not mistaken for coverage.

Finding 1 — none of the three binaries is code-signed

VirusTotal reports **no** `signature_info` for any of the three: no signer, no signing date, no verification status. For an 11 MB client that administers physical access control, that means:

- **No authenticity check is possible** at install or update time by the operator or by tooling.
- Application-allowlisting by publisher certificate **cannot** be used for this product — it must be allowlisted by hash, which in turn requires a trustworthy hash source.
- A trojanized `SystemGalaxy.exe` would be indistinguishable from a genuine one by signature, because the genuine one has none. That makes hash-baselining the *only* integrity control, which is exactly what this corpus provides — and is the strongest argument for keeping these three hashes in the known-good set.

Verified locally, 2026-10-23 — this is no longer an inference. `Get-AuthenticodeSignature` was run against all three held binaries. Every one returns `Status: NotSigned` with `SignerCertificate: <none>`, and all three confirm as valid PE images (`MZ` magic), so the result is not an artefact of a truncated or misidentified download. The VT metadata and the local check agree: **System Galaxy 11.7.0.1 and 11.8.3.1 ship unsigned.**

Finding 2 — two different binaries declare the same version

`A0EAFE84…` (10,920,960 B) and `67B90FDF…` (10,997,520 B) **both declare 11.8.3.1**, yet differ by 76,696 bytes and were first seen two years apart (2023-03-27 and 2025-11-07).

So **the version string does not identify the binary.** Practically: an asset inventory recording "System Galaxy 11.8.3.1" does not tell you which build is installed, and a change-management process that verifies version-only will not detect a swap between these two. Combined with Finding 1 — no signature — version plus publisher together are insufficient to establish what is running. **Hash verification is the only reliable discriminator for this product.**

This is unremarkable as vendor practice (rebuilds without a version bump are common) but it matters here precisely because there is no signature to fall back on.

Detection consequence

Control	Usable for System Galaxy?
Publisher-certificate allowlisting	**No** — unsigned
Version-string verification	**No** — ambiguous across builds
Hash allowlisting against a known-good catalog	**Yes** — the only one that works

That makes this vendor a clean illustration of why the hash baseline exists, and it is the line to carry into PB-05 and PB-17: for System Galaxy, an unexpected hash is the signal, because neither signature nor version will tell you anything.

CVE / advisory research — none found, stated as such

No CVE, ICS-CERT advisory or vendor security bulletin for Galaxy Control Systems or System Galaxy was found in this pass. Searches returned only unrelated "Galaxy" products.

Three readings, and the honest answer is that this pass cannot distinguish them:

1. Few vulnerabilities have been publicly reported in this product line.
2. It has received little security-research attention — plausible for a niche access-control vendor without a bug-bounty or published PSIRT process.
3. The vendor does not publish advisories where researchers would find them.

"No CVE found" is not "no vulnerabilities exist", and it is certainly not a clean bill of health. For a 463-device fleet the absence of advisory history is better treated as an **absence of information** than as evidence of safety — and it argues for a direct check of the panels rather than reliance on the public record. A targeted pass against CISA's ICS advisory archive and the vendor's own support site is the obvious next step, and was not performed here.

Status

Item	State
Public firmware download	**No** — `partner.galaxysys.com` partner-gated; registration **pending approval**
Management software acquired	**Yes** — 3 `SystemGalaxy.exe` builds (11.7.0.1, 11.8.3.1 ×2) via VT Intelligence
Panel firmware (508/508i/600/635)	**No** — not obtained; not present in VT
Rootfs extraction	**N/A** — PE resources only, no filesystem
Code signing	**Absent — confirmed locally.** `Get-AuthenticodeSignature` = `NotSigned`, no signer cert, on all three valid PE binaries
Behavioural baseline	**Effectively none** — 2 behaviour reports carry data, so per-vendor statistical differential is **not viable** (see vendor-exposure-vs-coverage.md)
CVE research pass	**Performed, nothing found** — treated as missing information, not as safety

Priority actions

1. ~~Confirm the signing finding locally~~ — **done 2026-10-23: all three `NotSigned`, no signer certificate.** The finding is verified and safe to brief.
2. **Chase the partner approval** — panel firmware for 463 devices is the real gap, and no alternative route to it exists (VT does not hold it).
3. **Hash-allowlist the three known-good builds** now, since neither signature nor version can serve that purpose for this product.
4. **Targeted CISA/vendor advisory pass** before this brief is used to assert anything about the vendor's vulnerability posture.